

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA DI AI GOVERNANCE GESTIONE DEI SISTEMI DI INTELLIGENZA ARTIFICIALE

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO085_00	00	29/04/2026	8
Redatto da	Approvato da	Classificazione	Stato
RSGI	AD – Francesco Epifani	Distribuito a tutto il personale	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
29/04/2026	29/04/2026	29/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e campo di applicazione

La presente procedura definisce le modalità di governance dei sistemi di Intelligenza Artificiale (AI) utilizzati o introdotti da Toscana Diagnostica, al fine di garantire la conformità al Regolamento (UE) 2024/1689 (AI Act), la sicurezza dei pazienti e degli operatori, la qualità dei risultati clinici e la trasparenza nei confronti delle parti interessate. La procedura si applica a tutti i sistemi AI - sviluppati internamente, acquisiti da terzi o integrati in dispositivi medici - presenti o pianificati nel perimetro operativo di Toscana Diagnostica, ivi compresi i sistemi AI utilizzati in ambito clinico (refertazione assistita, decision support, analisi imaging, pre-screening, biomarkers prediction), in ambito laboratoristico (autovalidazione di risultati, controllo della qualità, analisi delle code di lavoro), in ambito amministrativo e di customer experience (chatbot, scheduling intelligente, analytics, automazione di processi).

La procedura disciplina cinque ambiti operativi: (i) inventario dei sistemi AI in uso e pianificati con relativa classificazione del rischio secondo lo schema dell'AI Act; (ii) governance dei contratti con fornitori AI con clausole specifiche di compliance; (iii) controlli human-in-the-loop per i sistemi ad alto rischio; (iv) monitoraggio post-deployment con sorveglianza degli incidenti gravi; (v) formazione e sensibilizzazione del personale sull'uso responsabile dell'AI.

Si integra con TD-SGI-PRO070 (NIS2) per gli aspetti di cybersicurezza dei sistemi AI, con TD-SGI-PRO071 (Rischio del Laboratorio) e TD-SGI-PRO015 (Rischio Clinico) per la valutazione del rischio AI nelle attività cliniche, con il Modello 231/2001 per la prevenzione di reati che possano essere commessi mediante l'uso di sistemi AI, con le procedure dell'Area 09 Privacy per il trattamento di dati personali da parte di sistemi AI (Reg. UE 2016/679, GDPR).

2. Riferimenti normativi e documentali

Norma / Documento	Ambito
Regolamento (UE) 2024/1689 (AI Act)	Disciplina europea dei sistemi di intelligenza artificiale
Regolamento (UE) 2024/1183 (atto delegato)	Specifiche tecniche per gli high-risk AI systems
Regolamento (UE) 2017/745 (MDR)	Dispositivi medici - per AI integrata in DM
Regolamento (UE) 2017/746 (IVDR)	Dispositivi medico-diagnostici in vitro - per AI integrata
Regolamento (UE) 2016/679 (GDPR)	Trattamento dei dati personali
D.Lgs. 138/2024 (NIS2)	Cybersicurezza dei sistemi AI critici
UNI CEI EN ISO/IEC 23053:2023	Framework per sistemi AI con apprendimento automatico
UNI CEI EN ISO/IEC 23894:2024	Gestione del rischio AI
UNI CEI EN ISO/IEC 42001:2023	Sistemi di gestione AI (AI Management Systems)
UNI CEI EN ISO/IEC 24028:2020	Trustworthiness of AI
NIST AI Risk Management Framework	Framework di gestione del rischio AI di riferimento internazionale
Linee guida Garante Privacy IA	Indicazioni nazionali su AI e protezione dati personali
TD-SGI-MAN001_00	Manuale del Sistema di Gestione Integrato

TD-SGI-PRO070_00		Procedura di Adeguamento alla Direttiva NIS2
TD-SGI-PRO071_00		Gestione del rischio del Laboratorio (ISO 22367)
TD-SGI-PRO015_00		Procedura di gestione del Rischio Clinico
TD-SGI-PRO079_00		Gestione del Sistema Informativo di Laboratorio (LIS)
TD-SGI-PRO034_00		Procedura di qualificazione e valutazione dei fornitori (Area 14)
TD-SGI-PRO057_00 PRO063_00	÷	Procedure dell'Area 09 Privacy
TD-SGI-RPT002_00		Aggiornamento Report Benchmark - AI Act P1-D

3. Definizioni

Termine	Definizione
Sistema AI	Sistema basato su macchine progettato per operare con vari livelli di autonomia che, per obiettivi espliciti o impliciti, deduce, dagli input ricevuti, come generare output (predizioni, contenuti, raccomandazioni, decisioni) (art. 3, par. 1, AI Act)
Provider AI	Persona fisica o giuridica che sviluppa o fa sviluppare un sistema AI con l'obiettivo di immetterlo sul mercato o metterlo in servizio (art. 3, par. 3, AI Act)
Deployer (Utilizzatore) AI	Persona fisica o giuridica che utilizza un sistema AI sotto la propria autorità (art. 3, par. 4, AI Act). Toscana Diagnostica è prevalentemente un deployer di sistemi AI di terzi
High-risk AI system	Sistema AI classificato ad alto rischio ai sensi dell'art. 6 e degli Allegati I e III dell'AI Act (es. sistemi AI in dispositivi medici regolati MDR/IVDR; AI utilizzata per decisioni che impattano l'accesso a servizi sanitari, l'assunzione del personale, la valutazione delle prestazioni)
Limited-risk AI system	Sistema AI a rischio limitato (art. 50): chatbot, deepfake, sistemi che interagiscono con persone fisiche - obblighi di trasparenza
Minimal-risk AI system	Sistema AI a rischio minimo (es. filtri spam, ricerca semantica) - nessun obbligo specifico
Prohibited AI practices	Pratiche AI vietate ai sensi dell'art. 5 dell'AI Act (es. sistemi di social scoring, manipolazione cognitiva, riconoscimento emozioni nei luoghi di lavoro non giustificato)
Human-in-the-loop (HITL)	Sistema in cui un operatore umano valida o conferma l'output del sistema AI prima dell'azione effettiva sul paziente o sul processo
Conformity assessment	Procedura per dimostrare la conformità di un sistema AI ai requisiti dell'AI Act (per i sistemi high-risk: Allegati VI e VII)
AI literacy	Competenze, conoscenze e comprensione che consentono al personale di utilizzare in modo informato i sistemi AI (art. 4 AI Act)
Incidente grave AI	Malfunzionamento o evento che ha causato o potrebbe causare la morte o un grave deterioramento della salute di una persona, o gravi danni a beni o ambiente (art. 73 AI Act)

4. Ruoli e responsabilità

La governance dei sistemi AI a Toscana Diagnostica si articola sui ruoli seguenti, con responsabilità integrate nel SGI esistente.

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

4.1 Alta Direzione

Approva la presente procedura e ogni revisione. Approva l'inventario dei sistemi AI ad alto rischio. Garantisce le risorse per la conformità all'AI Act. Riceve il riesame annuale sull'AI Governance in sede di Riesame della Direzione del SGI.

4.2 RSGI

Presidia la procedura, coordina l'inventario AI, classifica il rischio dei sistemi, conduce le valutazioni di conformità, mantiene aggiornato il Registro dei Sistemi AI. Coordina l'integrazione con le altre procedure SGI (Privacy, NIS2, Risk Management Lab e Clinico, Modello 231).

4.3 IT Manager

Mantiene l'inventario tecnico dei sistemi AI in uso. Gestisce gli aspetti di cybersicurezza dei sistemi AI in coerenza con TD-SGI-PRO070 (NIS2). Verifica le caratteristiche tecniche dei sistemi AI prima dell'integrazione (interoperabilità, sicurezza, conformità GDPR).

4.4 DPO (Data Protection Officer)

Verifica la conformità GDPR di ogni sistema AI che processa dati personali. Conduce la DPIA (Data Protection Impact Assessment) per i sistemi ad alto rischio o che processano dati di salute. Mantiene il registro dei trattamenti AI.

4.5 Direttore Sanitario / Direttore di Laboratorio

Approva l'introduzione di sistemi AI in ambito clinico o diagnostico. Valida la classificazione del rischio per i sistemi AI utilizzati nel processo clinico. Ratifica le decisioni di disattivazione di sistemi AI in caso di incidenti gravi.

4.6 Owner del sistema AI (utilizzatore primario)

Per ogni sistema AI introdotto si designa un "owner" - responsabile operativo del corretto utilizzo, del monitoraggio post-deployment, della segnalazione di malfunzionamenti o anomalie. L'owner è tipicamente un Dirigente Tecnico di branca per i sistemi clinici, l'IT Manager per i sistemi di supporto.

4.7 Personale utilizzatore

Tutto il personale che utilizza un sistema AI: deve aver completato la formazione AI literacy obbligatoria; segnala tempestivamente malfunzionamenti, deviazioni o incidenti dell'AI; rispetta le modalità di uso definite per ciascun sistema (in particolare l'human-in-the-loop dove previsto); mantiene il principio di responsabilità professionale anche in presenza di output AI.

4.8 Organismo di Vigilanza ex D.Lgs. 231/2001

Riceve informativa su incidenti gravi AI che possano configurare reati presupposto del Modello 231 (in particolare reati informatici, reati colposi gravi, reati ambientali, eventuali nuovi reati ESG/AI introdotti dal legislatore).

5. Modalità operative

5.1 Inventario dei sistemi AI

Il RSGI mantiene il "Registro dei Sistemi AI" (modulo di nuova emissione TD-SGI-MOD197_00, in elaborazione) articolato sui campi seguenti: identificativo del sistema; provider; tipologia; ambito di utilizzo (clinico, laboratoristico, amministrativo, customer experience); finalità; categorie di dati processati; classificazione del rischio AI Act; presenza di marcatura CE come dispositivo medico;

soggetto owner; data di introduzione; data di ultimo riesame. Il Registro viene aggiornato a ogni nuova introduzione di sistema AI e annualmente per riesame complessivo. Costituisce evidenza documentale per audit ACN, valutatori AI Act, audit interni del SGI.

5.2 Classificazione del rischio AI Act

Per ciascun sistema AI presente o di nuova introduzione si applica la classificazione del rischio in quattro fasce, con responsabilità del RSGI in coordinamento con il Direttore Sanitario per i sistemi clinici e con il DPO per gli aspetti privacy.

Fascia	Definizione AI Act	Esempi rilevanti per Toscana Diagnostica	Obblighi
Pratiche vietate	Art. 5	Riconoscimento emozioni dei dipendenti, social scoring del personale, manipolazione comportamento	Divieto assoluto di adozione
High-risk	Art. 6 + Allegati I-III	AI in dispositivi medici/IVD MDR/IVDR; AI per analisi imaging diagnostica; AI per decisioni di assunzione; AI per valutazione del personale	Conformity assessment, sistema gestione rischio, dataset documentati, sorveglianza umana, registro eventi, post-market monitoring, registrazione UE
Limited-risk	Art. 50	Chatbot di customer service; deepfake; sistemi che interagiscono con persone fisiche	Obblighi di trasparenza (informativa al fruitore)
Minimal-risk	—	Filtri spam; ricerca semantica; categorizzazione interna; raccomandazioni operative non clinicamente decisionali	Nessun obbligo specifico oltre alla normativa generale (GDPR, ecc.)

La classificazione è documentata sul Registro dei Sistemi AI con motivazione esplicita (riferimento agli Allegati AI Act). Per i sistemi che ricadono in zone di confine, il RSGI consulta il Direttore Sanitario, il DPO e, se necessario, un consulente specialistico AI Governance esterno prima di procedere all'introduzione.

5.3 Onboarding di un nuovo sistema AI

L'introduzione di un nuovo sistema AI segue il flusso seguente: (a) richiesta formale da parte dell'owner candidato con descrizione del sistema, della finalità e dei dati processati; (b) classificazione del rischio AI Act a cura del RSGI; (c) per sistemi high-risk: valutazione di conformity assessment del provider, verifica di marcatura CE-IVDR/MDR se applicabile, DPIA del DPO, valutazione della clausola contrattuale; (d) per sistemi limited-risk: verifica delle informative di trasparenza, valutazione GDPR; (e) approvazione finale: Direttore Sanitario per sistemi clinici, IT Manager per sistemi tecnici, RSGI per sistemi gestionali; (f) inserimento nel Registro dei Sistemi AI; (g) attivazione del monitoraggio post-deployment.

5.4 Clausole contrattuali per fornitori AI

I contratti con i fornitori di sistemi AI (sia high-risk che limited-risk) devono includere - direttamente o tramite addendum - le clausole minime seguenti.

#	Clausola contrattuale minima
1	Dichiarazione di conformità all'AI Act e indicazione della classificazione del rischio

	attribuita dal provider
2	Per sistemi high-risk: copia del conformity assessment ai sensi degli Allegati VI/VII e/o copia della marcatura CE come dispositivo medico
3	Per sistemi che processano dati personali: nomina del fornitore come Responsabile del Trattamento ex art. 28 GDPR; clausole di trasferimento extra-UE (SCC) ove applicabile
4	Obbligo di notifica al deployer entro 12 ore dalla scoperta di un malfunzionamento o di un grave incidente
5	Diritto del deployer alla documentazione tecnica del sistema, ivi compresa la natura e la qualità del dataset di training
6	Diritto di audit annuale sul fornitore (in proprio o tramite terzo)
7	Cooperazione attiva del fornitore in caso di indagini delle autorità competenti (AI Office, ACN, Garante Privacy)
8	Clausole di reversibilità ed exit con tempi e modalità di estrazione dei dati o dei modelli

5.5 Controlli human-in-the-loop

Per tutti i sistemi AI classificati high-risk e per tutti i sistemi AI utilizzati in attività cliniche, indipendentemente dalla classificazione, è obbligatorio un controllo human-in-the-loop: un operatore umano qualificato (medico, biologo, dirigente tecnico, tecnico autorizzato) deve validare l'output del sistema AI prima dell'azione effettiva sul paziente o sul processo. La validazione è tracciata sul LIS o sul sistema applicativo con timestamp, identificazione dell'operatore validatore, conferma esplicita. Eccezioni motivate al controllo HITL (es. sistemi di pre-screening con bassa criticità clinica) sono autorizzate caso per caso dal Direttore Sanitario e documentate nel Registro dei Sistemi AI.

5.6 Monitoraggio post-deployment

Per ogni sistema AI in produzione, l'owner mantiene il monitoraggio sui parametri seguenti, con frequenza commisurata alla criticità clinica: tasso di errore o falso positivo/negativo confrontato con l'uso umano; concept drift e performance drift; tempo di risposta del sistema; tasso di disattivazione manuale o di override; segnalazioni di malfunzionamento; gravi incidenti AI ai sensi dell'art. 73 AI Act. Il riesame del monitoraggio è almeno trimestrale per sistemi clinici e semestrale per sistemi gestionali. I risultati alimentano il Riesame della Direzione del SGI.

5.7 Gestione incidenti gravi AI

In caso di incidente grave attribuibile a un sistema AI: (i) sospensione immediata dell'utilizzo del sistema fino a chiarimento; (ii) segnalazione al provider entro 12 ore; (iii) segnalazione alle autorità competenti (Autorità di Vigilanza AI italiana - AgID/ACN coordinata con Ministero della Salute per sistemi medici - entro le tempistiche stabilite dall'art. 73 AI Act); (iv) attivazione contemporanea del flusso di gestione incidenti NIS2 (PRO070) se l'incidente compromette la sicurezza informatica del sistema; (v) attivazione del flusso GDPR (PRO057) se l'incidente comporta una violazione di dati personali; (vi) RCA e CAPA tracciate sul Registro dei Sistemi AI; (vii) informativa all'OdV.

6. Formazione obbligatoria e AI literacy

Coerentemente con l'art. 4 AI Act, il personale di Toscana Diagnostica che utilizza sistemi AI deve completare un percorso di formazione AI literacy commisurato al ruolo e alla criticità del sistema. Il piano formativo è coordinato dalla P&C e si articola come segue.

Destinatari	Contenuto	Modalità	Frequenza
Alta Direzione + Comitato Guida SGI	AI Act, governance del rischio AI, responsabilità apicali, sanzioni	Sessione frontale + e-learning	Annuale

RSGI + IT Manager + DPO	Procedura PRO085, classificazione del rischio, conformity assessment, DPIA AI	Corso esterno specialistico	Annuale
Direttore Sanitario, Direttore di Laboratorio, Dirigenti Tecnici	Uso clinico responsabile dell'AI, principio HITL, gestione incidenti gravi, integrazione con Risk Management clinico e di laboratorio	Workshop interno + ECM	Annuale
Personale clinico e tecnico utilizzatore	AI literacy di base, riconoscimento bias e malfunzionamenti, modalità HITL, segnalazione incidenti	E-learning + esercitazioni operative	Annuale + on-event (a ogni nuovo sistema)
Personale amministrativo e di customer experience	AI literacy di base, trasparenza con utenti, GDPR e AI	E-learning	Annuale

7. Indicatori di processo

KPI	Definizione	Target	Frequenza
% sistemi AI inventariati e classificati	Sistemi nel Registro / sistemi effettivamente in uso	100%	Trimestrale
% sistemi AI high-risk con conformity assessment documentato	High-risk con doc completa / totale high-risk	100%	Trimestrale
% personale con AI literacy completata	Personale con formazione attiva / personale rilevante	>= 95%	Semestrale
Incidenti gravi AI nell'anno	Numero incidenti notificati alle autorità	0	Annuale
% controlli HITL tracciati su LIS	Validazioni HITL tracciate / output AI clinici	100%	Mensile
% fornitori AI con clausole contrattuali AI Act	Fornitori conformi / totale fornitori AI	100% entro 2 ago 2026	Trimestrale
Tempo medio di sospensione post-incidente	Ore dalla scoperta alla sospensione del sistema	<= 4 ore	On-event

8. Allegati e documenti correlati

Codice	Tipo	Titolo	Stato
TD-SGI-MOD197_00	Modulo	Registro dei Sistemi AI di Toscana Diagnostica	In elaborazione (emissione entro 30 giugno 2026)
TD-SGI-MOD198_00	Modulo	Scheda di valutazione di un nuovo sistema AI (onboarding)	In elaborazione
TD-SGI-MOD199_00	Modulo	Notifica di incidente grave AI	In elaborazione
TD-SGI-	Istruzione di	Esecuzione del controllo human-in-	In elaborazione

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

IDL034_00	lavoro	the-loop sul LIS	
TD-SGI-PRO070_00	Procedura	Adeguamento NIS2 (cybersicurezza dei sistemi AI critici)	In vigore
TD-SGI-PRO071_00	Procedura	Gestione del rischio del Laboratorio	In vigore
TD-SGI-PRO015_00	Procedura	Gestione del Rischio Clinico (Area 7)	In vigore
TD-SGI-PRO079_00	Procedura	Gestione del LIS (per integrazione AI nel LIS)	In vigore
TD-SGI-PRO034_00	Procedura	Qualificazione fornitori (per fornitori AI)	In vigore
TD-SGI-PRO057_00 ÷ 063_00	Procedure	Privacy (Area 9) per sistemi AI che trattano dati personali	In vigore

9. Storico delle revisioni

Rev.	Data	Descrizione	Autore
00	29/04/2026	Prima emissione. Procedura di AI Governance conforme al Regolamento (UE) 2024/1689 (AI Act). Disciplina inventario dei sistemi AI di Toscana Diagnostica, classificazione del rischio in 4 fasce (vietati, high-risk, limited-risk, minimal-risk), onboarding di nuovi sistemi AI, clausole contrattuali per fornitori (8 clausole minime), controlli human-in-the-loop obbligatori per high-risk e per attività cliniche, monitoraggio post-deployment, gestione degli incidenti gravi AI con coordinamento NIS2/GDPR/231, formazione AI literacy obbligatoria per 5 categorie di personale, KPI di processo. Si integra con TD-SGI-PRO070 (NIS2), PRO071 (Risk Lab), PRO015 (Rischio Clinico), PRO079 (LIS), PRO057-063 (Privacy), PRO034 (fornitori). Recepimento priorità P1-D del Report Aggiornamento Q2 2026 (TD-SGI-RPT002_00). Abilita la conformità alla scadenza vincolante AI Act del 2 agosto 2026 per i sistemi ad alto rischio.	RSGI